

Chapter 4

Network Security

Network security basics

- Network security involves protecting the confidentiality, integrity, and availability of information across a connected system.

1. Threats on network

1. Threats on Network (Intentional & Unintentional)

- Threats are potential actions that can negatively impact systems or data, ranging from opportunistic cybercriminals to state-sponsored groups.

Cont..

- **Malware (Ransomware, Viruses, Worms, Trojans):** Software designed to damage, disable, or steal data.
- **Phishing & Social Engineering:** Deceptive communication designed to trick users into exposing sensitive information. Over 90% of cyberattacks start with phishing.
- **DDoS Attacks (Distributed Denial of Service):** Overwhelming network resources with traffic to render services unavailable.

Network Ransomware Attack:

- is a malicious cyber operation where attackers gain unauthorized access to a network, encrypt files across multiple systems, and demand payment for a decryption key.
- These attacks often involve stealing data for double extortion, threatening public release if the ransom is not paid

How to Mitigate Risk:

- **Backups:** Maintain secure, immutable, and offsite backups to restore systems without paying.
- **Patching:** Frequently update software and operating systems to fix vulnerabilities.
- **Access Control:** Use multifactor authentication (MFA) and implement network segmentation to prevent the lateral spread of infections

Cont..

- **Man-in-the-Middle (MitM):** Attackers intercept communication between network devices, common in unsecured WiFi or via rogue routers.
- **Insider Threats:** Risky actions, whether intentional (disgruntled employee) or negligent (careless staff), that bypass traditional security controls.
- **Zero-Day Exploits:** Attacks on unknown or unpatched software vulnerabilities.
- **AI-Powered Attacks:** Use of AI to automate phishing and adapt to security measures.
- **Supply Chain Attacks:** Targeting third-party vendors to infiltrate secure networks.

2. Weaknesses (Vulnerabilities)

- Vulnerabilities are flaws in hardware, software, or procedures that can be exploited by threats. www.nens.com
- **Unpatched Software/Legacy Systems:** Outdated software and missing patches, which account for many data breaches.
- **Weak/Stolen Credentials:** Over 80% of hacking incidents involve stolen credentials due to weak passwords or lack of MFA (Multi-Factor Authentication).
- **Misconfigured Firewalls/Security Devices:** Incorrectly configured security tools, such as open ports or default settings,
- **Unsecured IoT/OT Devices:** Internet of Things devices often lack proper security, acting as entry points.
- **Human Error/Lack of Awareness:** Negligent staff failing to follow protocols or clicking on malicious links.
- **Insecure APIs:** Improperly secured interfaces that allow unauthorized data access.

Trust

3. Trust (The Zero Trust Model)

- Traditional perimeter security is failing. Modern security relies on the **Zero Trust Architecture**, which operates on the principle of "never trust, always verify".
- **Lateral Movement Prevention:** By using micro segmentation, networks are divided into isolated zones, preventing attackers from moving across the network if one segment is breached.
- **Authentication Hardening:** Requiring MFA for all network access to mitigate credential theft.

4. Risk

- Risk is the potential for loss, damage, or destruction of assets when a threat exploits a vulnerability (Risk = Threat x Vulnerability).
- **Financial Loss:** Direct costs from ransom payments, recovery, and fines.
- **Operational Disruption:** System downtime stopping business processes.
- **Reputational Damage:** Loss of customer trust, which can be irreparable.

Mitigation and Best Practices

- **Continuous Vulnerability Management:** Regular scanning and patching of systems.
- **Advanced Threat Detection:** Using behavioral analysis and SIEM (Security Information and Event Management) platforms.
- **Employee Training:** Conducting phishing simulations and security awareness programs.
- **Data Encryption:** Encrypting data at rest and in transit

TCP/IP Suit Weaknesses and Buffer Overflows

- TCP/IP suite weaknesses stem from its original design prioritizing connectivity over security, featuring inherent lack of authentication and encryption across layers.
- Key risks include IP/ARP spoofing, SYN flooding, and session hijacking, while buffer overflows exploit unvalidated input to crash systems or execute malicious code, solvable via bounds-checking and patching.

Key TCP/IP Suite Weaknesses

- **Lack of Authentication/Encryption:** Protocols like ARP, IP, and TCP do not inherently verify the sender's identity or encrypt data, leading to eavesdropping and spoofing.
- **ARP Spoofing:** Attackers map their MAC address to a legitimate IP, hijacking network traffic.
- **IP Spoofing & Sequence Prediction:** Attackers impersonate trusted IP addresses and predict sequence numbers to hijack sessions.
- **SYN Flooding (DoS):** Exploits the TCP three-way handshake by leaving connections half-open, exhausting server resources.

Cont..

ARP spoofing

- ARP spoofing, also known as **ARP poisoning**, is a cyberattack that exploits a vulnerability in the Address Resolution Protocol (ARP) to intercept, modify, or block network traffic on a local area network (LAN).
- The attacker sends falsified ARP messages to link their Media Access Control (MAC) address with the Internet Protocol (IP) address of a legitimate network device, such as the default gateway.

ARP spoofing

- ARP spoofing (or ARP poisoning) is a method where an attacker sends fake Address ARP messages onto a local network to trick devices into thinking the attacker's machine is someone else—usually the default gateway (router).

Clear Scenario: The Coffee Shop Interception

- Imagine three persons on a public Wi-Fi network:
- **Victim (Your Laptop):** IP 192.168.1.5
- **Router (Gateway):** IP 192.168.1.1 | MAC AA:AA:AA:AA:AA:AA
- **Attacker (Hacker):** IP 192.168.1.10 | MAC CC:CC:CC:CC:CC:CC

ARP spoofing

1. The Normal State

- When your laptop wants to go to a website, it asks the network: *"Who has IP 192.168.1.1?"*. The Router replies: *"I do! My MAC is AA:AA:AA:AA:AA:AA."* Your laptop saves this in its **ARP Cache**. ACM Digital Library +1

2. The Attack

- The attacker uses a tool like Ettercap or arpspoof to flood the network with fake "replies":
- **To Your Laptop:** The attacker says, *"I am the Router (192.168.1.1), and my MAC is CC:CC:CC:CC:CC:CC."*
- **To the Router:** The attacker says, *"I am the Victim (192.168.1.5), and my MAC is CC:CC:CC:CC:CC:CC."*

ARP spoofing

3. The Result: Man-in-the-Middle (MitM)

- Because the ARP protocol has no way to verify these claims, both devices update their caches with the attacker's MAC address.
- Interception: Now, when you send a password to a website, your laptop sends the data to the attacker's MAC address.
- Forwarding: The attacker sees your password and then forwards the data to the real router so you don't notice any lag or connection loss

IP Spoofing & Sequence Prediction

- **Initiate the Spoofed Handshake**
- The attacker begins the TCP three-way handshake by lying about their identity.

=> Senario--

- **Action:** Attacker X launches a Denial of Service (DoS) attack, such as a [SYN flood](#), against Host T.
- **Step A:** X sends a SYN packet to S with the source IP forged as **Host T**.
- **Step B:** S sends a SYN/ACK back to **Host T** (the trusted host). X cannot see this packet because it goes to T.
- **Step C:** X predicts what the sequence number in that invisible packet was and sends an ACK back to S with the predicted "Acknowledgment Number".

- **Weaknesses by Layer:**

- **Network Layer (IP):** Vulnerable to traffic sniffing, DoS attacks, and IP spoofing.
- **Transport Layer (TCP/UDP):** Vulnerable to connection hijacking, port scanning, and fragmented packet attacks.

Buffer Overflows in Networking

Buffer overflows occur when a program writes more data to a buffer (temporary storage) than it can hold, overwriting adjacent memory.

- **Network Impact:** Malformed packets or excessive data sent to network services (e.g., DNS, HTTP, SIP) can crash systems or allow arbitrary code execution.
- **Causes:** Unsafe C library functions (e.g., strcpy(), gets()) that lack bound checking.

- **Mitigation:**
 - **Secure Coding:** Use functions that check buffer boundaries and validate all input.
 - **System Protection:** Employ ASLR (Address Space Layout Randomization) and stack protection (e.g., StackGuard).
 - **Patching:** Frequently update software to fix vulnerable applications.
- **Overall Defense Strategies**
- **Encryption:** Implement SSL/TLS or VPNs to encrypt data payload.
- **Segmentation & Firewalls:** Use firewalls and network segmentation to isolate critical infrastructure.
- **Intrusion Detection/Prevention (IDS/IPS):** Monitor network traffic for suspicious activity and spoofing attempts.

Web Application Firewall (WAF)

- A Web Application Firewall (WAF) is a security solution that filters, monitors, and blocks HTTP/HTTPS traffic to and from a web application, acting as a shield between the internet and the application.
- Operating at Layer 7 (Application Layer), it protects against web-specific attacks like SQL injection, cross-site scripting (XSS), and bot traffic.

Key Aspects of WAFs:

- **How it Works:** It operates as a reverse proxy, inspecting incoming traffic against a set of rules (policies) to identify malicious activity before it reaches the server.
- **Protection Focus:** WAFs are specifically designed to defend against common vulnerabilities, notably the OWASP Top 10.

- **Types of WAFs:**
 - **Cloud-based:** Easy to deploy, scalable, and often delivered as a service.
 - **Network-based:** Hardware appliances, often offering high performance.
 - **Host-based:** Software installed directly on the web server.
- **Security Models:** They use positive models (allow list), negative models (block list), or hybrid approaches to determine what traffic to allow.

security protocols

Application layer security (Web security)

- Application layer security (Web security) protects software and web applications at Layer 7 of the OSI model, focusing on defending against threats targeting application logic, data input, and user authentication.
- It secures web apps and APIs against attacks like SQL injection, XSS, and DDoS by using Web Application Firewalls (WAFs), input validation, encryption, and secure coding practices.
- Web security refers to the practices and technologies used to protect websites, web applications, and data from cyber threats and unauthorized access.
 - Protects data during transmission over the Internet.
 - Safeguards websites, servers, users, and applications.
 - Prevents data breaches, malware attacks, and hacking.
 - Essential due to the increasing number of cyberattacks.

Key Aspects of Application Layer Security

- **Protection Focus:** Defends against attacks that exploit software vulnerabilities rather than infrastructure flaws, such as SQL injection, cross-site scripting (XSS), parameter tampering, and Slowloris.
 - **Slowloris** - "low and slow" denial-of-service (DoS) attack that allows a single machine to take down a web server with minimal bandwidth
- **Key Techniques:**
 - **Input Validation & Sanitization:** Cleaning user-provided input to prevent malicious code injection.
 - **Authentication & Authorization:** Verifying user identity and controlling access rights.
 - **Encryption:** Protecting data in transit and at rest.
 - **Web Application Firewall (WAF):** Inspecting HTTP/HTTPS traffic to filter malicious requests.
 - **Secure Coding:** Developing applications with security in mind (e.g., using secure frameworks).

- **Common Attacks:**
 - **SQL Injection:** Injecting unauthorized SQL commands to access or destroy data.
 - **Cross-Site Scripting (XSS):** Injecting malicious scripts into web pages viewed by users.
 - **DDoS and HTTP Floods:** Overwhelming an application with malicious requests.
 - **Parameter Tampering:** Modifying parameters in a URL or form to manipulate user data.

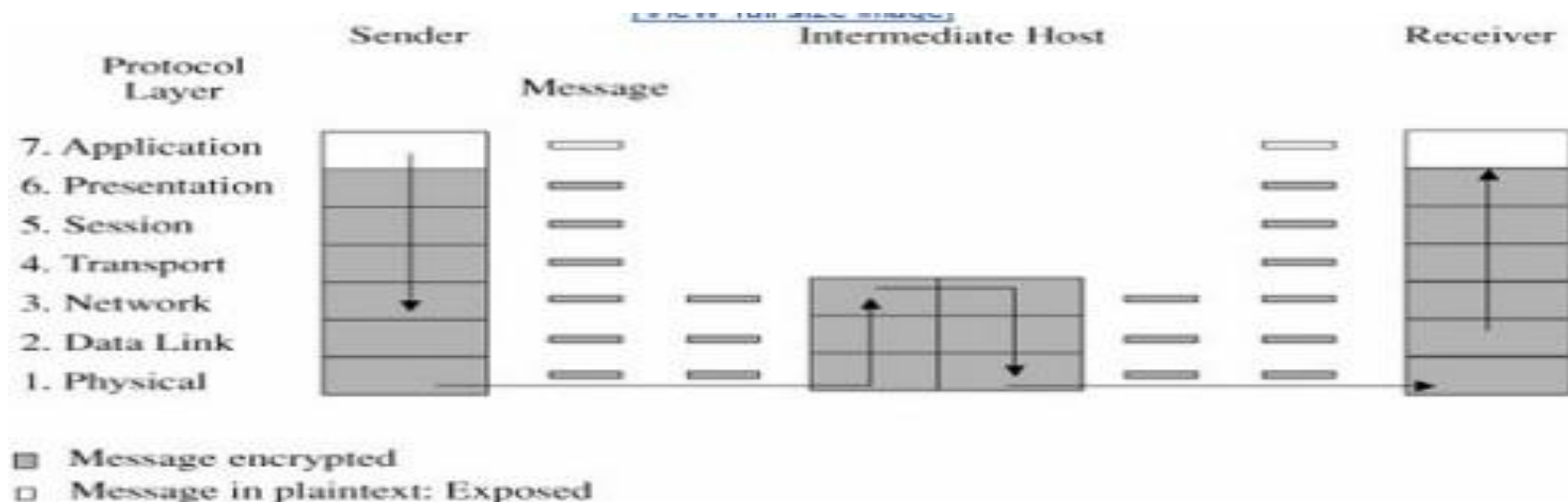
- **Importance:** Since the application layer is closest to the user, it is the most targeted layer, making it crucial to protect against data theft, unauthorized access, and system disruption.

Key Tools for Application Layer Security

- **WAF (Web Application Firewall):** Protects web apps by filtering HTTP requests.
- **SAST/DAST:** Static and Dynamic Application Security Testing tools.
- **API Gateways:** Manages and secures API traffic

End-to-End Encryption

- As its name implies, end-to-end encryption provides **security** from one end of a transmission to the other.
- The encryption can be **applied** by a hardware device between the user and the host. When end-to-end encryption is used, messages **sent** through several hosts are protected.



E-mail security

- Email security refers to the collective policies, technologies, and practices designed to protect email accounts, content, and communications from unauthorized access, loss, or compromise.
- It mitigates threats like phishing, malware, and data breaches.

Key Components of Email Security

- **Anti-Phishing & Malware Protection**: Scans for malicious links and attachments, often using sandbox "detonation" chambers to test files.
- **Encryption**: Secures email content so only authorized recipients can read it.
- **Authentication Protocols**:
 - Uses protocols such as SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail), and DMARC (Domain-based Message Authentication, Reporting, and Conformance) to verify the sender's identity and prevent spoofing.
- **Spam Filters**: Block unwanted and potentially dangerous bulk emails.
- **Data Loss Prevention (DLP)**: Prevents sensitive information from being sent outside the organization.

Best Practices for Protecting Emails

- **Enable Multi-Factor Authentication (MFA):** Adds a critical layer of security beyond just a password.
- **Security Awareness Training:** Educates users to recognize phishing attempts, as human error is a major vulnerability.
- **Use Strong, Unique Passwords:** Reusing passwords across accounts increases the risk of account takeover.
- **Regular Backups:** Ensures email data can be restored if compromised.

Common Threats

- **Phishing/Spear-Phishing:** Deceptive emails designed to steal credentials or sensitive data.
- **Business Email Compromise (BEC):** Fraudsters impersonate executives or trusted partners to trick employees into transferring funds or data.
- **Ransomware & Malware:** Malicious software delivered via attachments or links.

Transport layer security

- TLS is a cryptographic protocol designed to provide secure, encrypted communication over computer networks, primarily the internet.
- It enables data privacy (encryption), integrity, and authentication, preventing eavesdropping and tampering.
- TLS is the modern successor to SSL and underpins HTTPS.

Key aspects of TLS include:

- **Functionality:** TLS protects data in transit by encrypting the connection between applications (e.g., web browser to server, email clients).
- **Three Pillars of Security:**
 - **Encryption:** Hides data from unauthorized parties.
 - **Authentication:** Verifies that the parties involved are who they claim to be.
 - **Integrity:** Ensures data cannot be modified during transfer without detection.

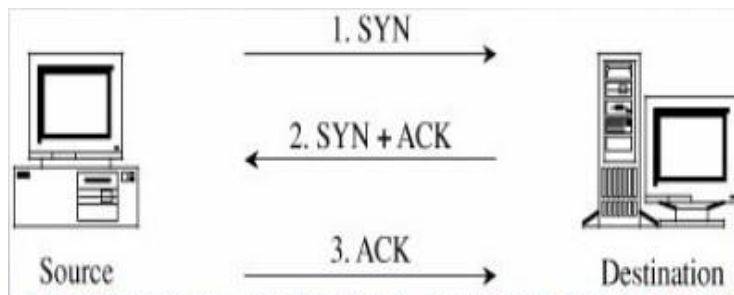
- **The Handshake:** Before data is exchanged, a "handshake" occurs where the client and server negotiate cryptographic algorithms and authenticate each other using digital certificates.
- **TLS 1.2/1.3:** Current standards include TLS 1.2 and 1.3, with 1.3 offering a faster, more streamlined, and more secure handshake.
- **Usage:** Used widely in HTTPS (web browsing), email (SMTP/IMAP), file transfers, and API interactions.
- **Difference from SSL:**
TLS is the updated, more secure version of SSL (Secure Sockets Layer).
- While often used interchangeably, TLS is the standard now, and older SSL protocols are considered insecure.

Attacks

Echo-Chargen

- This attack works between **two hosts**.
- **Chargen**: is a protocol that **generates** a stream of packets and used to **test** the network's capacity.
- The attacker **sets up** a chargen process on
- **HostA** that **generates** its packets as **echo packets** with a destination of **HostB** .
- Then, host A produces a stream of packets to which host B **replies** by **echoing** them back to host A. This series puts the network infrastructures of A and B into an **endless loop** .
- If the attacker makes B both the source and destination address of the first packet, **B hangs in a loop**, constantly **creating** and **replying** to its own messages.

- **Syn Flood** :another DOS attack is the syn flood.
 - This attack **implemented** on TCP protocol suite, which needs **connection** before actual data transmitted.
 - A session is established with a **3-way** handshake mechanism.



- The destination maintains a queue called the **Syn_Recv** connections, eventually the destination host will **timeout** the incomplete connection and **discard** it from its waiting queue.
 - attacker can deny service to the target by sending many SYN requests and never responding with ACKs, by filling the victim's **Syn_Recv** queue.

Network layer security

- Network layer security (OSI Layer 3) protects data as it moves across networks, focusing on IP packet integrity, authentication, and confidentiality.
- It primarily uses IPsec (Internet Protocol Security) for encryption and tunneling, protecting communication between hosts, sites, or remote users without needing application-level modification.

Key Aspects of Network Layer Security:

- **IPsec (IP Security):** The primary mechanism for network layer security, offering authentication (AH) and encryption (ESP) to ensure data confidentiality and integrity.
- **VPNs (Virtual Private Networks):** Frequently used for secure, encrypted site-to-site tunnels or remote access, leveraging IPsec.
- **Packet Filtering/Firewalls:** Firewalls block/allow traffic based on source/destination IP addresses, preventing unauthorized access.
- **Secure Routing Protocols:** Ensuring routing information is not tampered with, protecting the path data takes.
- **Transparency:** Because it operates at the network level, security mechanisms like IPsec can protect applications without modifying them.

Threats in Networks

- What **Makes** a Network Vulnerable?
 - Network environment are more vulnerable than stand alone environment
- Many points of attack both **targets** and origins
 - Access controls on one machine **preserve** the confidentiality of data on that processor.
 - An attack can come from any host to any host, so that a large network offers many points of vulnerability.
- **Sharing**: because networks enable resource and workload sharing, more users have the potential to access networked systems than on single computers.

Tools and techniques used by attackers

■ Port Scan

- An easy way to **gather** network information is to use a port scan. a program that used to **report** about network.
- **Port scanning tells to an attacker three things:**
 - Which **ports** or services are running and responding on the target system
 - What **operating system** is installed on the target system,
 - and What **applications** and versions of applications are present

There are different **tools** to scan a port freely and commercial

-nmap scanner by Fyodor at

-www.insecure.org/nmap.....free

-netcat, written by Hobbit, at

-www.l0pht.com/users/l0pht.....free

CyberCop Scanner, Secure Scanner (Cisco), and Internet Scanner-Commercial.

● Social Engineering

- involves using **social skills** and personal interaction to **get** someone to **reveal** security-relevant information and perhaps even to do something that permits an attack.

● Intelligence

- From **a port scan** the attacker **knows what is open** and from social engineering, the attacker **knows** certain **internal** details.
 - Intelligence is the general term for collecting information.
 - In security it often refers to **gathering discrete bits** of information from various sources and then putting them together like the pieces of a puzzle.
- **Trained spies** may follow employees to **lunch** and **listen** in from nearby **tables** as coworkers discuss security matters.

Threats in Transit

- **Eavesdropping and Wiretapping** :the term eavesdrop implies **overhearing** without expending any extra effort.
Example , an attacker (a system administrator) is eavesdropping by **monitoring** all traffic passing through a node.
- **Wiretap** , which means **intercepting** communications through some effort.
 - **Passive wiretapping** is just "**listening**" much like eavesdropping.
 - **Active wiretapping** means **injecting** something into the communication.

eavesdropping

- **eavesdropping** is a type of network attack where an unauthorized third party secretly intercepts, monitors, or captures private data as it travels across a network.
- It is one of the most common threats in cybersecurity because it can be difficult to detect, as network performance often remains normal during the attack.

How Network Eavesdropping Works

- Attackers typically target **unsecured or unencrypted networks**, such as public Wi-Fi hotspots, where data is sent in plain text and easily read.

- There are two primary categories of Eavesdropping :
- **Passive Eavesdropping:** The attacker silently listens to network traffic without making changes.
 - They often use **packet sniffers** (like [Wireshark](#)) to capture data packets containing passwords, financial details, or private messages.
- **Active Eavesdropping:** The attacker interacts with the network to redirect or alter traffic.
 - A common example is a **Man-in-the-Middle (MitM)** attack, where the attacker positions themselves between two communicating parties to relay and potentially modify their information

- **Packet sniffer** :is the act of **capturing** packets of data flowing across a computer network.
 - The software or device used to do this is called a **packet sniffer**.
 - Using a packet sniffer it is possible to capture data like **passwords, IP addresses, protocols** being used on the network and other sensitive data that is not secured by encryption.
 - It is possible to detect an **unauthorized packet sniffer** on the wire using a device called **a Time Domain Reflectometer(TDR)** .
- **Spoofing** :is when an attacker **pretends** to be someone else in order **gain** access to restricted resources or steal information.
 - Spoofing attack is a situation in which one person or program **successfully masquerades** as another by **falsifying** data and thereby gaining an illegitimate advantage.

- **IP spoofing**

- involves **changing** the packet headers of a message to **indicate** that it came from an IP address other than the **true** source.

Example spoofing are masquerading, session hijacking, and man-in-the-middle attacks.

- **Masquerade** In a masquerade one host **pretends** to be another.

● Session hijacking

- is intercepting and carrying on a session begun by another entity.
- Suppose two entities have **entered** into a session but then a third entity **intercepts** the traffic and carries on the session in the name of the other.

Example : using Telnet If a system administrator **logs** in remotely to a privileged account, **a session hijack utility** could interfere in the communication and pass commands as if they **came** from the administrator.

● Man-in-the-Middle Attack : is a similar form of attack, in which one entity interferes between two others.

- man-in-the-middle is that a usually participates from the **start** of the session, whereas a session hijacking occurs **after** a session has been established.

Denial of Service (DOS) attacks

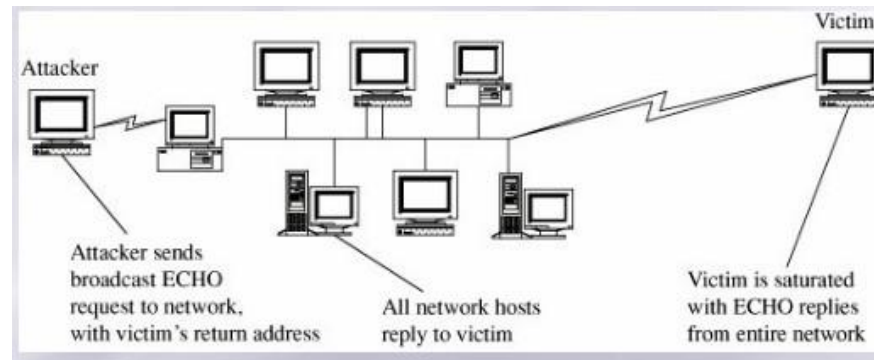
- one of the most popular choices of **Internet hackers** who want to
- **disrupt** a network's operations.
- An attempt to make a computer or network resource **unavailable** to its intended users
 - DoS to the **network bandwidth** of targeted server
 - DoS to the **computing resource** of targeted server Memory, CPU
 - DoS to the **vulnerability** in targeted server Causing server OS crash (buffer overflow bug, logic bug, etc) Causing server program crash (e.g., Apache, SQL)
- **Distributed Denial-of-Service (DDoS) attack**
 - Sending attack **packets** from multiple computers.
 - The most primitive denial-of-service attack is **flooding a connection**.

● Ping of death

- is a simple attack Since ping **requires** the recipient to **respond** to the ping request.
- In ping of death attacker send **a flood of pings** to the intended victim.
- The ping packets will **saturate** the victim's bandwidth.

● Smurf

- The attacker **send broadcast** echo request by using victim address.



■ A domain name server(DNS) Attacks

- is a table that **converts** domain names like ATT.COM into **network addresses** like 211.217.74.130; this process is called **resolving the domain name**.
- By causing it to **cache** false entries (called DNS cache poisoning), an attacker can **redirect** the routing of any traffic, with an obvious implication for denial of service.
 - In this attack, the poisoned DNS cache redirected users to advertising sites that received money from clients each time a user visited the site.

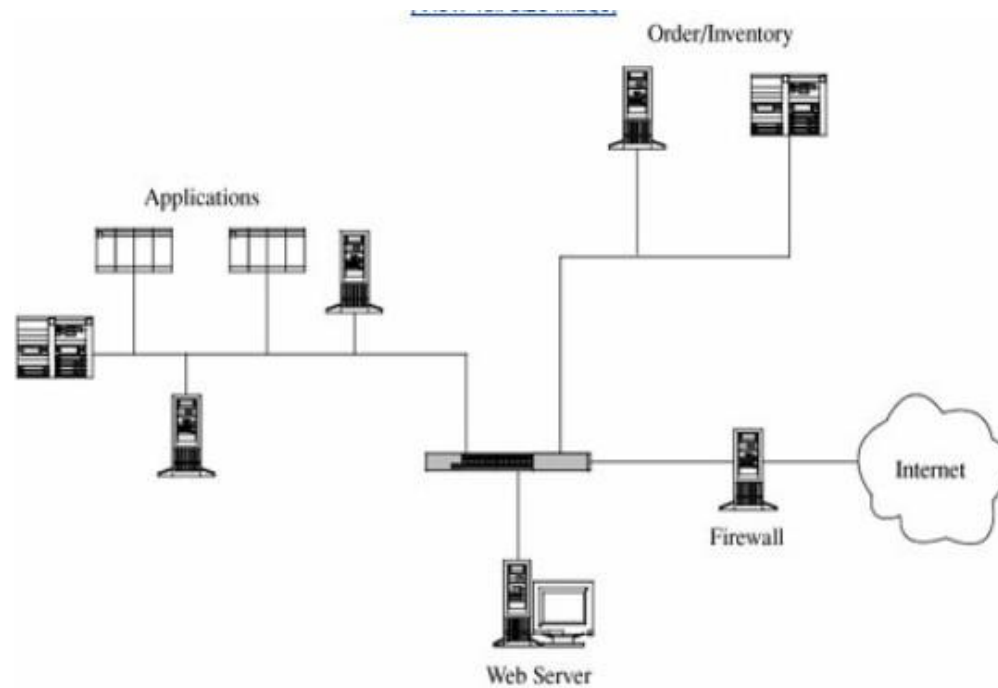
Network Security Controls

- Assume your network implements electronic commerce for users of the Internet.

A. Segmentation

- **a web server**, to handle users' HTTP sessions
- **application code**, to present your goods and services for
- purchase **a database** of goods, and perhaps an accompanying inventory to the count of stock on hand and being requested from suppliers a database of orders taken
 - If all these activities were to run on one machine, your network would be in trouble:
 - Any compromise or failure of that machine would destroy your entire commerce capability
- If all these activities were to run on one machine, your network would be in **trouble**.
- Any compromise or failure of that machine would **destroy** your entire commerce capability.

● Segmented Architecture



■ Redundancy

- Allowing a function to be **performed** on more than one
- node. A better design would have two **servers**, using what is called **failover mode**.
 - In failover mode the servers communicate with each other **periodically**, each determining if the other is still active.
 - If one fails, the other takes over processing for both of them.

■ Single Points of Failure

- We should ask if there is a single point in the network that, if it were to fail, could **deny** access to all or a significant part of the
- network. Good network design **eliminates** single points of failure.
- Distributing the Database placing **copies** of it on different network segments, perhaps even in different physical locations can **reduce** the risk of serious harm from a failure at any one point.

Network Layer vs. Transport Layer:

- While transport-layer security (TLS/SSL) protects specific applications (like HTTPS) by securing connections between endpoints,
- network-layer security (IPsec) secures the entire communication channel itself.

Data Link layer security

- Data Link layer (Layer 2) security protects node-to-node communication within a LAN by ensuring integrity, authentication, and confidentiality of frames.
- Key measures include enabling:
 - switch port security,
 - using 802.1X authentication,
 - implementing Dynamic ARP Inspection (DAI),
 - configuring VLANs for segmentation, and adopting WPA3 for wireless,
 - targeting risks like MAC flooding and ARP spoofing.

Data Link layer security

Key Security Threats & Vulnerabilities (Layer 2)

- **MAC Flooding/CAM Table Exhaustion:** Attacks that overwhelm switches with fake MAC addresses, forcing them to behave like hubs and broadcast traffic.
- **ARP Spoofing/Poisoning:** Attacker sends fake ARP messages to map their MAC address to a legitimate IP address, enabling man-in-the-middle attacks.
- **VLAN Hopping:** Bypassing switch VLAN restrictions to access unauthorized network segments.
- **DHCP Attacks:** Starving the network of DHCP addresses or acting as a rogue DHCP server.

Common Data Link Layer Security Measures

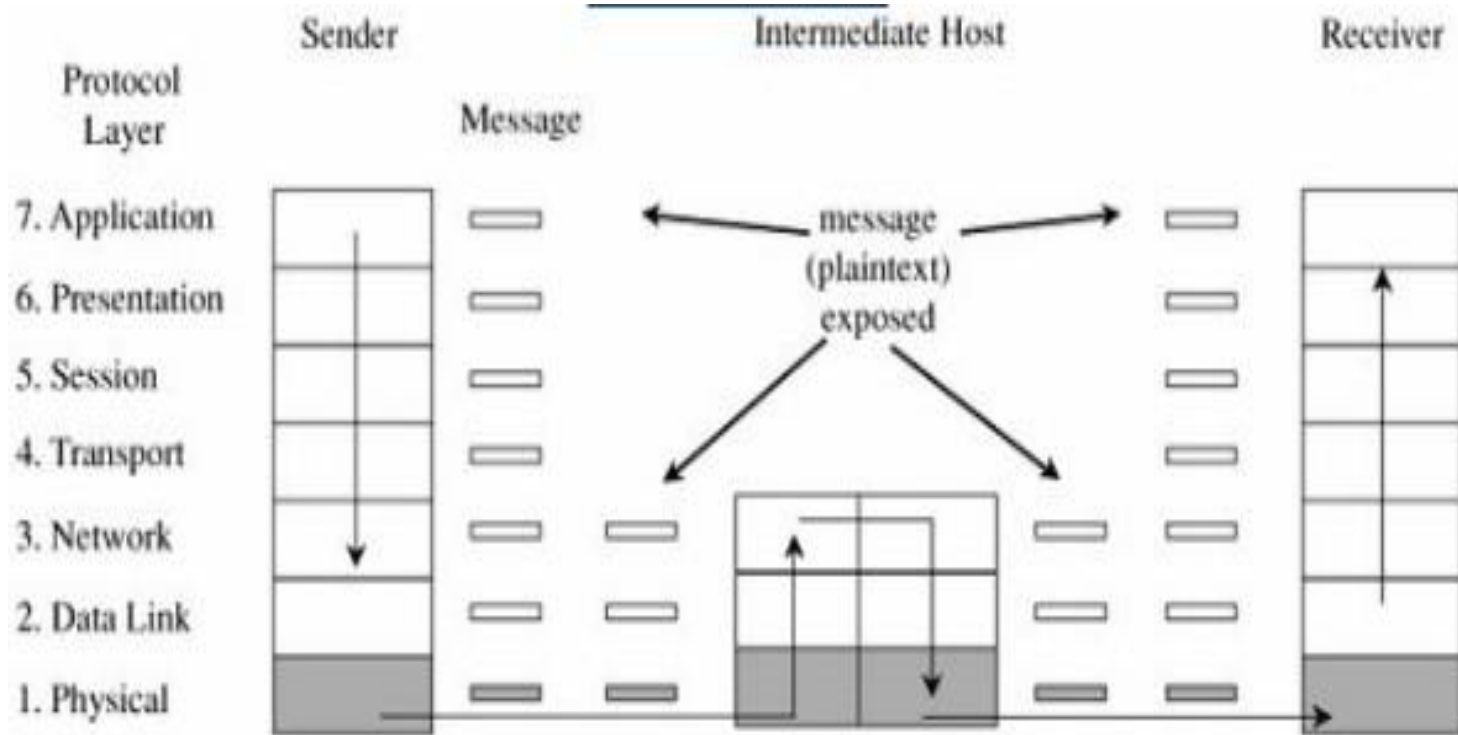
- **Port Security:** Restricts the number of MAC addresses allowed on a switch port to prevent MAC address spoofing.
- **IEEE 802.1X Authentication:** Ensures only authorized devices can connect to the switch port.
- **Dynamic ARP Inspection (DAI):** Validates ARP packets in a network to prevent ARP poisoning.
- **VLAN Segmentation:** Isolates network traffic for better control and reduced risk.
- **WPA3/WPA2:** Provides encryption for wireless links, a major component of Layer 2 security. QRC Assurance & Solutions Pvt. Ltd +1
- **Importance of Layer 2 Security**

Data link layer security is critical because it secures the immediate, local communication path.

 - If this layer is compromised, higher layers (like IP or application) might not detect the attack, as they assume the underlying transport is reliable.

Link Encryption

- data are encrypted just **before** the system places them on the physical communications link.
- In this case, encryption occurs at **layer 1** or **2** in the OSI model.
- Encryption protects the message in **transit** between two computers, but the message is in **plaintext** inside the hosts
- Link encryption is **invisible** to the operating system as well as to the operator.
- Link encryption is especially **appropriate** when the transmission line is the point of greatest vulnerability.



Physical Security

- Physical security involves protecting the actual hardware, facilities, and infrastructure from unauthorized physical access or damage.
- Even the best encryption cannot protect a server if someone can physically walk away with it.

Key Controls & Measures

- **Perimeter Security:** Use of fences, security guards, and bollards to control access to the building.
- **Access Control Systems:** Implementation of biometric scanners (fingerprints, retina), keycards, or PIN pads at entry points to server rooms.
- **Surveillance:** CCTV cameras and motion sensors to monitor and record activity in sensitive areas.
- **Environmental Controls:** Protecting hardware from natural threats using fire suppression systems, HVAC (heating, ventilation, and air conditioning) to prevent overheating, and Uninterruptible Power Supplies (UPS) for power stability.
- **Device Hardening:** Physical locks on server racks and disabling unused ports (like USB) to prevent the manual extraction of data.

Wireless Security

- Wireless security focuses on protecting radio frequency (RF) signals and the devices that communicate over them.
 - Since wireless signals travel through the air, they are inherently more vulnerable to eavesdropping than wired connections.

Common Protocols:

- **WPA2 (Wi-Fi Protected Access 2):** Uses **AES (Advanced Encryption Standard)** and has been the industry standard for years.
- **WPA3:** The modern successor to WPA2. it provides individualized data encryption and stronger protection against "brute-force" dictionary attacks.
- **IEEE 802.1X:** An authentication framework that requires devices to provide credentials (via a RADIUS server) before they can join the network.

Wireless-Specific Threats

- **Rogue Access Points:** An unauthorized Wi-Fi access point installed on a network without the administrator's knowledge, creating a backdoor.
- **Evil Twin Attack:** A fraudulent Wi-Fi access point that appears to be legitimate (e.g., "Guest_WiFi") to trick users into connecting so the attacker can intercept their traffic.
- **Wardriving:** The act of searching for Wi-Fi networks from a moving vehicle to map out vulnerable entry points.
- **Packet Sniffing:** Using specialized software to capture and analyze wireless data frames "out of the air".

Mitigation Strategies:

- **SSID Hiding:** Disabling the broadcast of the network name so it doesn't appear in "available networks" lists.
- **MAC Filtering:** Restricting network access to only specific, pre-approved hardware addresses.
- **VPN Usage:** Encrypting the data payload even if the wireless connection itself is compromised